Human Authentication

Thierry Sans

Intuitive definition

What is human authentication?

➡ Determining the "identity" of a person

Why would I need to authenticate you?

➡ To be sure that you are the person that you claim to be

Identification vs Authentication

Identification

- Assigning a set of data to a person or an organization (usually called the *subject*)

Authentication

- Making a safe link between a subject and one or several of identities

Authentication Factors

Something that you know

- ✓ Password, PIN number, secret handshake, passphrase, secret key, secret questions …

Something that you have

- ✓ IDs, physical key, badges, smart card, mobile phone, hardware device …

Something that you are or do (biometrics)

- ✓ Fingerprint, voice recognition, face recognition …

Something that you know



✓ **Good as long as** you remember the secret and nobody can uncover or guess this secret

- **Gets compromised as soon as** someone else knows this secret and is able to use it

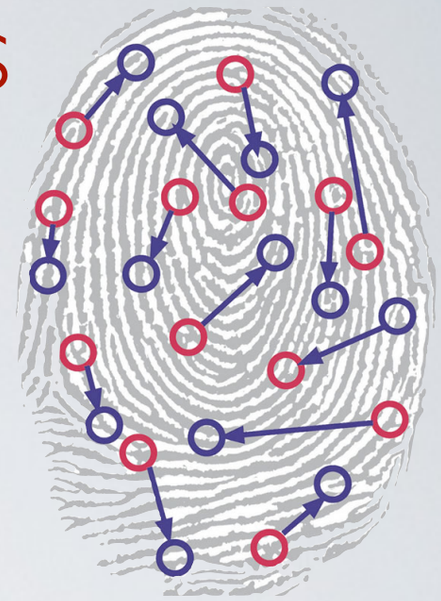
Something that you have



✓ **Good as long as** you do not lose or damage the token and there is only one instance for a "given token"

- **Gets compromised as soon as** someone can duplicate or fake the token

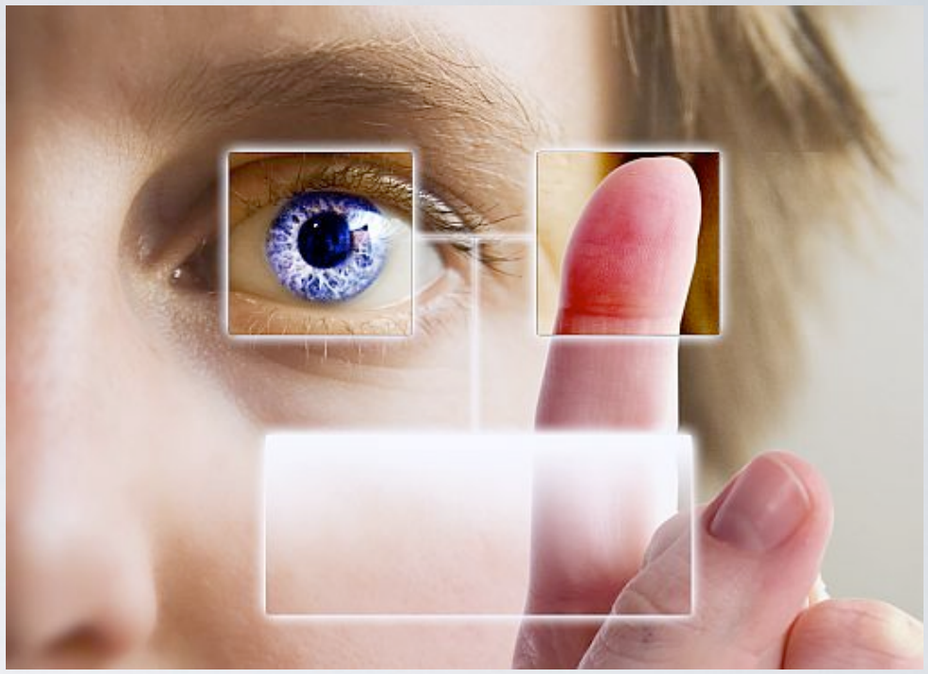
Something that you are or do - Biometrics



An authenticator takes a measure of your physical characteristics and compare it with an existing measure of what you are suppose to be

- ✓ The robustness depends on the precision of this measure and the similarity criteria (often not strict equality)
- ◉ But how to recover from an attack where the physical characteristics are compromised?

Something that you are



- ✓ **Good as long as** you act or look like the same and nobody cannot be "good enough" in doing what you do or "pretend" to look like you

- ◉ **Gets compromised as soon as** someone can "nearly" act like your "nearly" look like you (depending on the authenticator)

Multi-factor authentication



	Something that you		
	know	**have**	**are**
ID card		X	X
Credit Card	X	X	
Biometric Passport		X	X X
Two-factor authentication	X	X	

Choosing the authentication mechanism

➡ Driven by the risk analysis and the costs
How hard is it to?

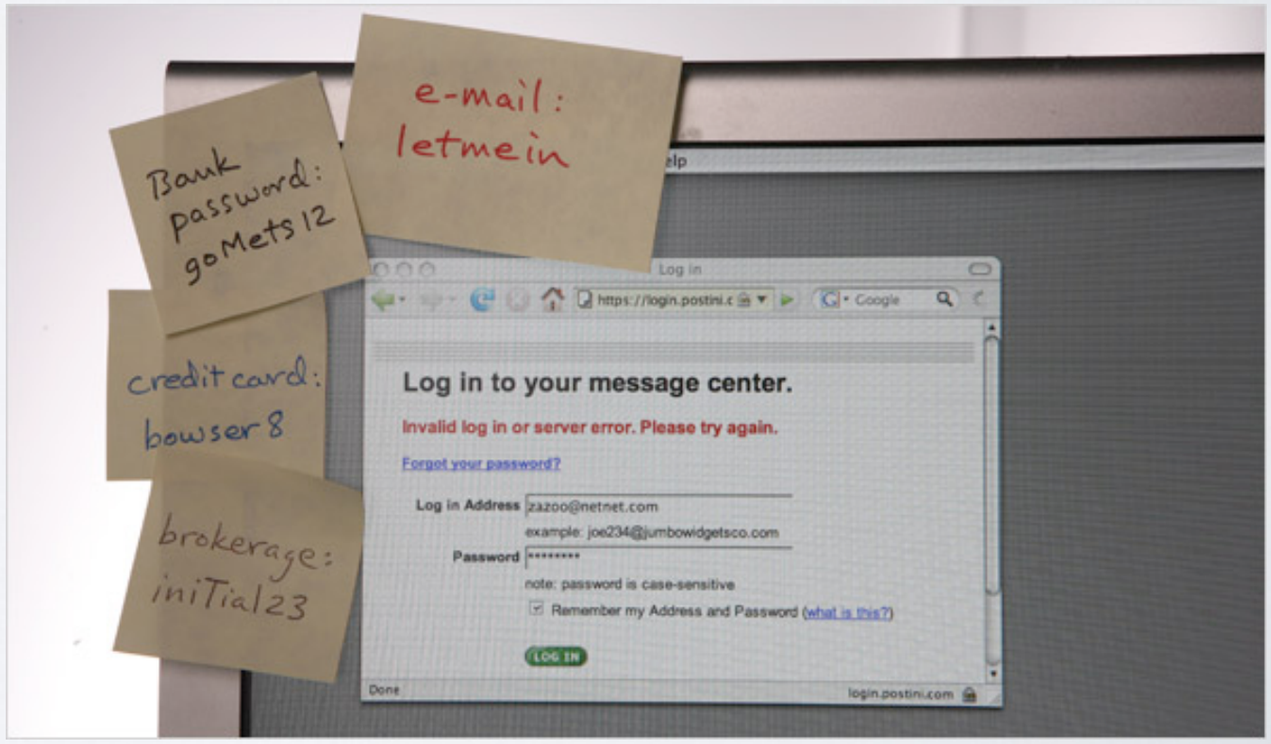
- Make you reveal your secret password
- Duplicate a credit card
- Fake your fingerprints

◉ There is no perfect authentication



Something else to consider - usability

- How restrictive is the use of several authentication mechanisms?
- How the users will use handle and appropriate the authentication process?



Going Further
Federated authentication and Single-Sign on

Can the authentication process been delegate to a third party?

Can we use the same identity over different information system?

➡ Identity management systems e.g. *OpenID Connect* for authentication and *OAuth 2.0* for delegated authorization

Passwords

Managing Passwords

- How many passwords do you have?
- What password for what kind of application?
- How often do you change your password?
- How do you remember your password?
- How strong is your password?

Using passwords

- How are passwords transmitted on the network?
- How and where are passwords stored when signing up?
- How are passwords compared with an input when signing in?

Hacking passwords

- How would you crack someone's password?
- How would you steal someone's password?

Cracking a password from the login box

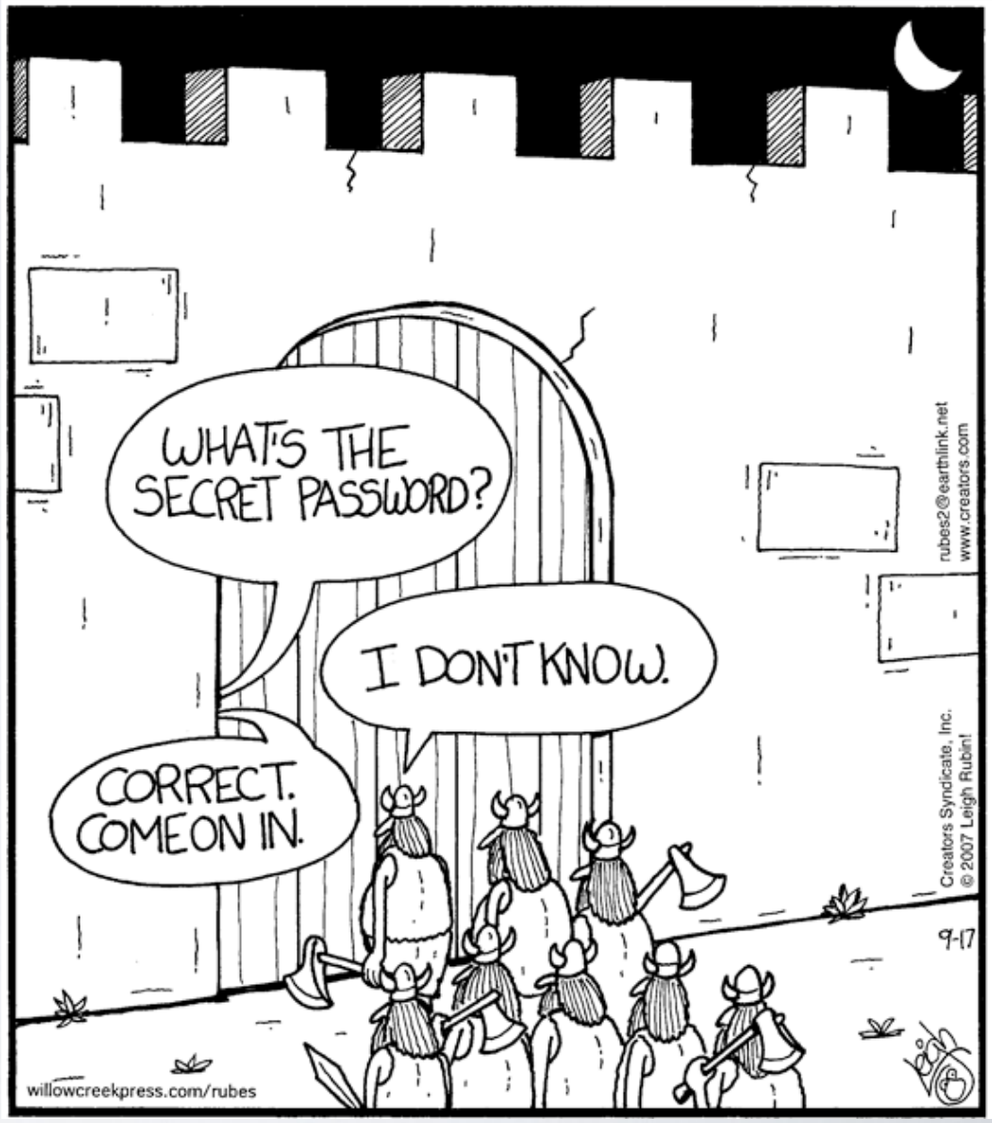
How to crack a password on challenge/response?

- Guessing attack (default and common passwords)
- Brute force attack
- Dictionary attack

What are the counter-measures?

- Timing
- Limit number of tries

Tool: THC Hydra



Stealing someone's password

How to get a password in clear?

- Social engineering - Phishing
- Data mining (emails, logs)
- Keyloggers (keystroke logging)

How to get an encrypted or hashed password?

- Know where it is stored and breach that storage

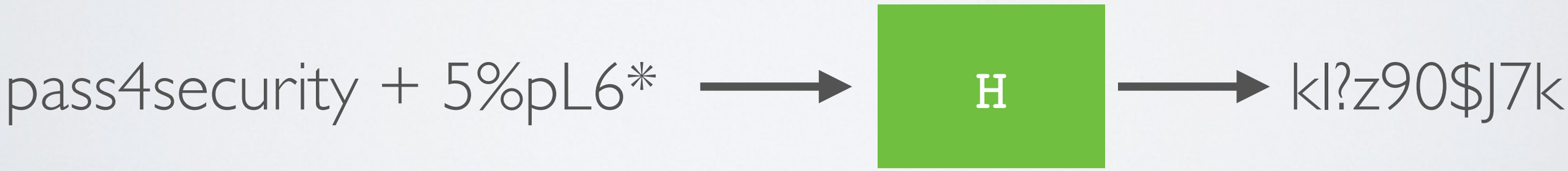
How passwords are stored

- **In clear** (really bad)
- **Encrypted**
  (undesirable in most cases and complex to manage)
- **Hashed** (bad)
- **Salted Hash** (better and easy to manage)

Unsalted passwords



Salted password



Specialized Password-Hashing Functions

Goal: Protect passwords against brute-force attacks

Principle: Make each guess slow i.e computationally expensive

- By including a mandatory salt
- By making the hash function CPU and memory intensive
- By having multiple passes that cannot be parallelized using GPUs or specialized hardware

◉ SHA2 & SHA3 are not suitable hash functions because too fast

✓ **Argon2** (recommended), scrypt and bcrypt

Password Strength

Number of Characters	Numbers Only	Lowercase Letters	Upper and Lowercase Letters	Numbers, Upper and Lowercase Letters	Numbers, Upper and Lowercase Letters, Symbols
4	Instantly	Instantly	Instantly	Instantly	Instantly
5	Instantly	Instantly	46 mins	2 hours	3 hours
6	Instantly	37 mins	2 days	5 days	1 week
7	Instantly	16 hours	3 months	10 months	2 years
8	Instantly	2 weeks	12 years	50 years	132 years
9	2 hours	1 year	636 years	3k years	9k years
10	20 hours	32 years	33k years	191k years	645k years
11	1 week	839 years	1m years	11m years	45m years
12	3 months	21k years	89m years	737m years	3bn years
13	2 years	567k years	4bn years	45bn years	221bn years
14	23 years	14m years	241bn years	2tn years	15tn years
15	229 years	383m years	12tn years	175tn years	1qd years
16	2k years	9bn years	653tn years	10qd years	75qd years
17	22k years	259bn years	33qd years	675qd years	5qn years
18	228k years	6tn years	1qn years	41qn years	372qn years

Time it takes a hacker to brute force your password in 2026

Hardware: 16 x RTX 5090
Password hash: bcrypt (10)

Hive Systems

Read more and download at
hivesystems.com/password

Cracking a hashed password

How can an attacker recover a password from its stored hash? (From easier to harder)

- **Rainbow table attack:** use precomputed hash tables to recover passwords from unsalted hashes
- **Password-list attack:** try common, weak, or previously leaked passwords
- **Dictionary attack:** generate password candidates from words, names, dates, and predictable variations
- **Brute-force attack:** systematically try all possible character combinations until a match is found

Tools: John the Ripper, HashCat

68 comments
11.3K
2.3K
3.6K
+1 402
More +

Millions of LinkedIn passwords reportedly leaked online

A hacker says he's posted 6.5 million LinkedIn passwords on the Web -- hot on the heels of security researchers' warnings about privacy issues with LinkedIn's iOS app.



by Lance Whitney | June 6, 2012 6:31 AM PD

Follow

Update 1:08 p.m. PT: *LinkedIn confirms that passwords were "compromised."*

LinkedIn users could be facing yet another security problem.

A user in a Russian forum says that he has hacked and uploaded almost 6.5 million LinkedIn passwords, according to The Verge. Though his claim has yet to be confirmed, Twitter users are already reporting that they've found their hashed LinkedIn passwords on the list, security expert Per Thorsheim said.

CNET | News
Reviews | News | Download | CNET TV | How To | Deals

38 comments
865
265
72
+1 78
More +

Hackers post 450K credentials pilfered from Yahoo

Credentials posted in plain text appear to have originated from the Web company's Yahoo Voices platform. The hackers say they intended the data dump as a "wake-up call."



by Steven Musil | July 11, 2012 11:06 PM PDT

Follow

Yahoo has been the victim of a security breach that yielded hundreds of thousands of login credentials stored in plain text.



The hacked data, posted to the hacker site D33D Company, contained more than 453,000 login credentials and appears to have originated from the Web pioneer's network. The hackers, who said they used a union-based SQL injection technique to penetrate the Yahoo subdomain, intended the data dump to be a "wake-up call."

What a good password policy looks like in 2026

NIST SP 800-63B-4 (July 2025) recommends or requires :

- **At least 15 characters** when used as a single factor
  a lower minimum of 8 permitted when used with MFA
- **No arbitrary password composition requirements or routine expiration**
- **Screening against commonly used and compromised passwords**
- Support for password managers and autofill
- Rate limiting for online guessing

Is your password on a password-list?

Has your password been leaked in a previous breach?

https://haveibeenpwned.com/

➡ **If yes** do not only change that password for that service but **change it for all services that use the same one**

Beyond Passwords

Common two-factor authentication methods

Using a verification email

Stronger than just having a password but not considered as second factor by NIST

Using mobile device

- by using a push approval application (weak)
- by sending a one-time password through an SMS
- by using a one-time password application

Using a hardware authentication device

e.g Hardware Token/Fob, Smart Cards, USB Security Keys

One-time password

Registration: The service provide users with unique secret keys (using a QR code usually) to store in their mobile application

Authentication: The device generates a one-time password based on the secret stored in the device

There are two standards both based on MAC

- HOTP (HMAC-based one-time password) based on a counter
- **TOTP** (Time-based one-time password)
  based on time quantum ~ usually 30 seconds

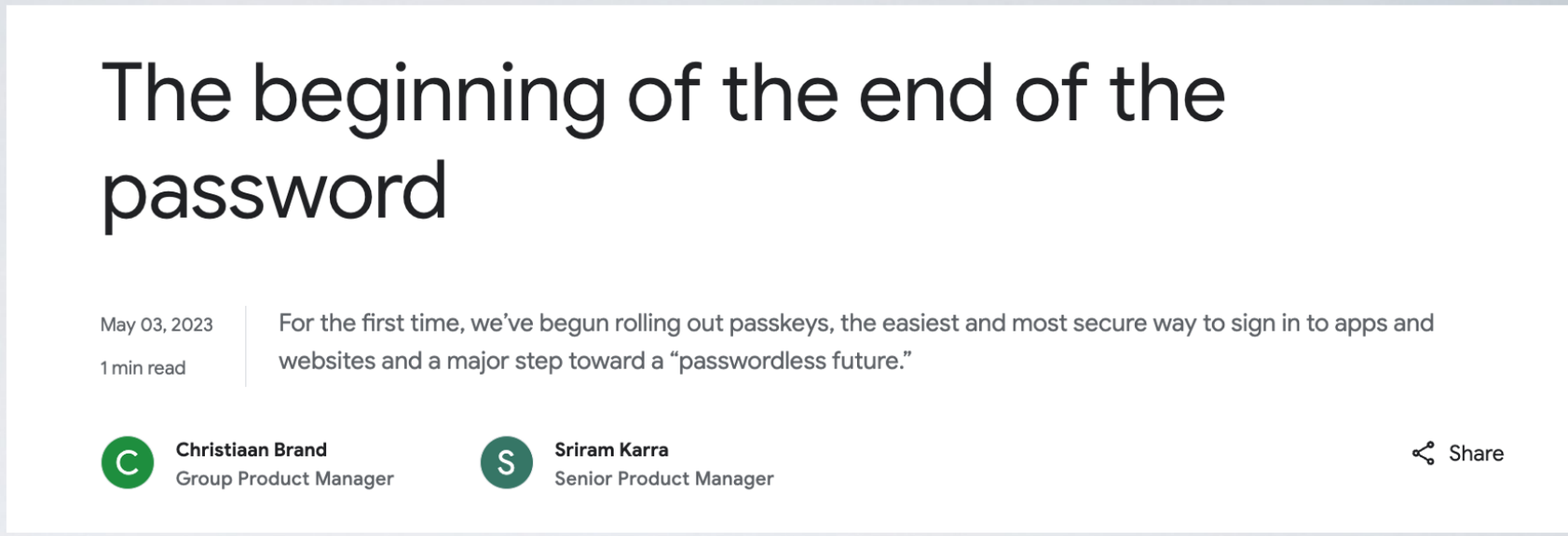
An example of a USB Security Key : *YubiKey*

Hardware device (USB and/or Bluetooth) to provide authentication

- Support one-time password (HOTP or TOTP)
- Support digital signature (OpenPGP and PKCS#11)
- Compatible with *WebAuthn*
- Can combine a biometrics factor



WebAuthn



The beginning of the end of the password

May 03, 2023

1 min read

For the first time, we've begun rolling out passkeys, the easiest and most secure way to sign in to apps and websites and a major step toward a "passwordless future."

C **Christiaan Brand**
Group Product Manager

S **Sriram Karra**
Senior Product Manager

Share

➡ Also called FIDO2 standard or **Passkeys**

Registration: The device generates a key pair and sends it to the service

Authentication: the service sends a challenge to the device that will returned it signed with the private key

✓ The device stores the private key inside **a safe storage** (e.g. keychain, password manager, Trusted Computing Module - TPM, USB Security Key) that comes with its own local authentication (e.g. master password, fingerprints, face recognition)

The weakest link : Account Recovery

What happen when users

- forget their login and/or password
- lose their devices
  with its stored TOTP secrets and/or passkeys

Account recovery can be implemented:

- using an email address (that can also be compromised)
- using another device (that can also be lost)
- using a seed passphrase to derive a private key directly (that can also be lost)

- Account recovery hijacking is often another attack vector

Another weak link : The Session

A user authenticates once, then accesses resources across many subsequent requests **but how does the system remember that authentication?**

➡ This is the concept of **session** that can be achieved using several mechanisms such as session keys, session cookies, bearer tokens, refresh tokens and so on

◉ Session hijaking is yet another attack vector
(more about that topic towards the end of semester)